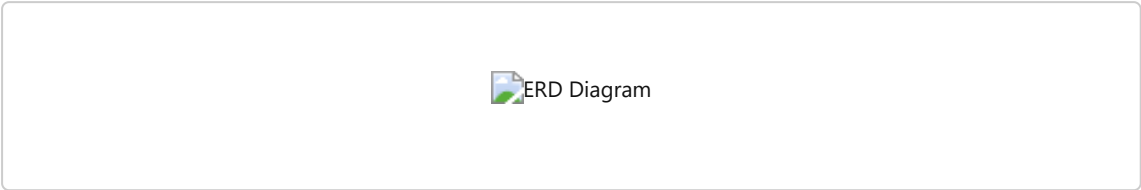


Database Schema

Full PostgreSQL schema reference. All tenant-scoped tables enforce Row-Level Security (RLS) + Eloquent HasTenantScope.

April 2026 · 12 tables · Optimised for black & white print

Section 1 — Entity Relationship Diagram



RLS enforced on all tables except `tenants` and `plans` . PHI columns use AES-256-GCM at the application layer.

Section 2 — Schema Conventions

Convention	Rule
Primary keys	uuid for patient-facing tables, bigserial for internal/log tables
Tenant scoping	Every table (except tenants, plans) has a non-nullable tenant_id uuid FK
Soft deletes	All mutable tables include deleted_at timestampz (nullable)
PHI columns	Marked with PHI — these use AES-256-GCM encrypted casts at the application layer
Timestamps	All tables have created_at and updated_at (except audit_log_entries — immutable, no updated_at)
JSONB	Used for flexible clinical data that varies per procedure (quiz answers, AI scores)

Section 3 — Tables Overview

Table	Description
tenants	Represents a clinic (SaaS tenant). The root entity for all tenant-scoped data.
plans	Subscription tier definitions. Managed by AestheticAI admin — not tenant-editable.
users	Clinic staff accounts (coordinators, surgeons, admins, owners). Scoped to a tenant.
patients	Patient identity records. PHI columns are AES-256-GCM encrypted at the application layer.
procedures	Master list of supported procedures. Defines what quizzes and photo protocols are available.
quiz_definitions	JSON-defined quiz branching logic per procedure. Loaded by the quiz engine at runtime.
evaluations	Core table. One row per patient evaluation submission.
photos	Patient photos associated with evaluations. Stored in S3; this table tracks metadata only.
audit_log_entries	Append-only, immutable log of all PHI access and state changes. Never deleted, never updated.
webhook_deliveries	Tracks outbound webhook delivery attempts to clinic CRM endpoints.
api_tokens	Bearer tokens for the External REST API v1.
magic_links	One-time coordinator portal access tokens sent in evaluation notification emails.

Section 4 — Migration Checklist

When creating a new table, verify each item:

- ☐ Has `tenant_id uuid NOT NULL REFERENCES tenants(id)` (unless it's a global lookup table)
- ☐ Has `created_at` , `updated_at` timestamps
- ☐ Has `deleted_at` for soft deletes (unless append-only like `audit_log_entries`)
- ☐ PHI columns are noted with a comment and use encrypted casts in the model
- ☐ RLS policy created and enabled
- ☐ `FORCE ROW LEVEL SECURITY` applied (catches application-role bypasses)
- ☐ Indexes created for `tenant_id` , all FK columns, and all `WHERE` columns used in queries
- ☐ Rollback migration included (drop indexes → drop table)